

README: KIT CRA-CYBER GQM+PRAGMATIC v2.1

Evaluación de Madurez Ciberseguridad con Integración de Metodologías

Versión: 2.1 — Enero 2026

Idioma: Español

Alcance: Organizaciones españolas (NIS2, GDPR, DORA, ENS, ISO 27001)

Metodología: GQM (Goal-Question-Metric) + PRAGMATIC (9 criterios calidad)

¿QUÉ ES CRA-CYBER GQM+PRAGMATIC?

Es un **kit integral de evaluación de madurez ciberseguridad** que:

- ✓ Alinea **objetivos estratégicos nacionales** con **métricas técnicas operacionales**
- ✓ Valida que cada métrica sea **prácticamente útil** (PRAGMATIC)
- ✓ Proporciona **trazabilidad completa** desde regulación hasta datos técnicos
- ✓ Cuantifica **costes reales de personal** (CAsPeA)
- ✓ Demuestra **ROI defensible** ante CFO y Junta Directiva

NOVEDAD: INTEGRACIÓN GQM+PRAGMATIC

GQM (Goal-Question-Metric, 1985):

- Metodología top-down de alineación de objetivos
- Establece cadena: Objetivo → Preguntas → Métricas medibles
- Usado por NASA, Motorola, Microsoft

PRAGMATIC (Glasgow et al., 2013):

- 9 criterios para validar *utilidad práctica* de métricas
- Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable

Integración única en marco español:

- GQM define *QUÉ medir* (alineación estratégica)
- PRAGMATIC valida *SI es útil* (calidad métrica)
- Resultado: Métrica excelente = Estratégica + Útil + Implementable

6 DOCUMENTOS INCLUIDOS

1 Marco Integrativo GQM+PRAGMATIC (1_Marco_Integrativo_GQM_PRAGMATIC.md)

Contenido:

- 4 Goals estratégicos nacionales (Cumplimiento, CAsPeA, Madurez, Riesgos)
- 12-15 Questions por goal
- 30+ Métricas operacionales
- Trazabilidad: Goal → Question → Métrica → Acción
- Ejemplo end-to-end: NIS2 Compliance → MTTD Improvement

Para: CISOs, Directivos, Investigadores

Uso: Referencia conceptual + justificación metodológica

2 [Matriz de Evaluación PRAGMATIC Completa \(2_Matriz_Evaluacion_PRAGMATIC_Completa.md\)](#)

Contenido:

- 25+ métricas CAsPeA evaluadas contra 9 criterios PRAGMATIC
- Escala 1-4 (Deficiente a Excelente) por métrica
- Puntuación media PRAGMATIC para cada métrica
- Recomendación: IMPLEMENTAR / REVISAR / RECHAZAR

Ejemplo métrica:

M2.1: Coste Total CAsPeA (€/año)

- Predictivo: 3/4 (CAsPeA ↑ → Capacidades ↑)
- Relevante: 4/4 (CFO la requiere)
- Accionable: 4/4 (CISO controla hiring)
- Genuino: 4/4 (Datos nómina verificables)
- Significativo: 4/4 (60-70% presupuesto)
- Preciso: 4/4 (±2% error)
- Oportuno: 4/4 (Mensual disponible)
- Independiente: 4/4 (No covarría)
- Rentable: 4/4 (Datos internos)
- MEDIA: 3.8/4 ✓ EXCELENTE → IMPLEMENTAR

Para: Analistas de datos, Auditores, CISOs técnicos

Uso: Validación de calidad métrica + decisión GO/NO-GO

3 [Mapeo Normativo Completo \(3_Mapeo_Normativo_Preguntas_Requisitos.md\)](#)

Contenido:

- 58 preguntas encuesta × 6 marcos normativos
- Tabla maestra: Pregunta → Requisito NIS2/GDPR/DORA/ENS/ISO/NIST
- Cobertura por normativa (100% NIS2, 97% ISO 27001, etc.)
- Matriz inversa: Requisito → Preguntas que lo validan

Ejemplo:

NIS2 Anexo III – Requisito 4: "Capacidad detección anomalías"

- P4.1: ¿Dispone SIEM?
- P4.2: ¿Cobertura fuentes?
- P4.3: ¿Capacidad sofisticada?
- P4.4: ¿MTTD <60 min?
- P4.7: ¿Mejora continua?

Cumplimiento: Si 5/5 respuestas favorables → CUMPLE

Para: Auditores, Responsables cumplimiento, Reguladores

Uso: Auditoría regulatoria, demostrativo de compliance

4 [Plantilla Excel GQM+PRAGMATIC \(4_Plantilla_Excel_GQM_PRAGMATIC.md\)](#)

Contenido:

- 12 hojas: Datos, GQM, CAsPeA, Benchmarking, IMG, ROI, Validación, Dashboard, Recomendaciones,

Exportación, Diccionario, Auditoría

- Fórmulas automáticas: CAsPeA → IMG → ROI
- Validación de datos integrada
- Dashboard ejecutivo con gráficos

Flujo:

1. Copiar respuestas encuesta → Hoja 1
2. Sistema valida automáticamente
3. Calcula CAsPeA, IMG, ROI
4. Genera Dashboard (Hoja 8)
5. Exporta reportes (Hoja 10)

Para: Analistas datos, Encuestadores

Uso: Procesamiento automático de respuestas → Reportes ejecutivos

5 [Plantilla PowerPoint Ejecutivo \(5_Plantilla_Reporte_Ejecutivo_PowerPoint.md\)](#)

Contenido:

- 12-14 slides estructurados narrativamente
- Slide 1: Portada + GQM framework
- Slide 2: Alineación estratégica (pirámide Goals-Questions-Metrics)
- Slide 3: Validación PRAGMATIC (tabla criterios)
- Slide 4: IMG (Madurez General)
- Slide 5: Desglose por función NIST (radar)
- Slide 6: CAsPeA (donuts/barras costes)
- Slide 7: Cumplimiento normativo
- Slide 8: ROI análisis comparativo
- Slide 9: Brechas críticas + Top 3 recomendaciones
- Slide 10: Roadmap 12 meses
- Slide 11: Presupuesto desglosado
- Slide 12: Llamada a acción
- Slide 13: Q&A

Para: CISOs presentando ante C-Suite, Junta Directiva

Uso: Presentación ejecutiva (20-25 min) + aprobación presupuesto

6 [Este README \(6_README_Kit_CRA_Cyber_GQM_PRAGMATIC.md\)](#)

Contenido:

- Descripción del kit completo
- Instrucciones de implementación paso a paso
- Cronograma recomendado
- Requisitos técnicos
- FAQ
- Contacto y soporte

Para: Todos (guía de inicio rápido)

Uso: Orientación inicial + troubleshooting

DIFERENCIA vs. VERSIÓN ANTERIOR (v1.0)

Aspecto	v1.0	v2.1 GQM+PRAGMATIC
Alineación	Preguntas genéricas	Goals – Questions – Metrics (GQM)
Validación métricas	Sin validación formal	9 criterios PRAGMATIC por métrica
Trazabilidad regulatoria	Mapeo básico	6 marcos normativos × 58 preguntas
Documentos	4 archivos	6 archivos profesionales
Automatización	Excel manual	12 hojas con fórmulas completas + Dashboard
ROI demostración	Cualitativo	Cuantitativo (CAsPeA – Pérdida evitada – ROI %)
Rigor científico	Encuesta observacional	Metodología GQM (NASA) + PRAGMATIC (literatura)

IMPLEMENTACIÓN: 5 PASOS

PASO 1: PREPARACIÓN (Semana 1-2)

- 1.1) Descargar 6 documentos desde repositorio
- 1.2) Revisar Marco GQM+PRAGMATIC (Doc 1)
- 1.3) Validar métricas contra PRAGMATIC (Doc 2)
- 1.4) Mapeador normativo (Doc 3)
- 1.5) Preparar Excel template (Doc 4)

PASO 2: LANZAMIENTO ENCUESTA (Semana 3)

- 2.1) Configurar Google Forms / Qualtrics
- 2.2) Copiar 58 preguntas desde Doc 1
- 2.3) Enviar invitaciones (150-250 respondientes)
- 2.4) Plazo: 3-4 semanas

PASO 3: ANÁLISIS (Semana 6-8)

- 3.1) Exportar respuestas a Excel (Doc 4, Hoja 1)
- 3.2) Sistema valida automáticamente
- 3.3) Cálculos: CAsPeA → IMG → ROI (Hojas 2-6)
- 3.4) Dashboard genera automático (Hoja 8)

PASO 4: VALIDACIÓN PRAGMATIC (Semana 7)

- 4.1) Revisar Matriz PRAGMATIC (Doc 2)
- 4.2) Métricas ≥3.5 → Usar en decisión
- 4.3) Métricas 3.0-3.5 → Validar con auditor
- 4.4) Métricas <3.0 → Revisar definición

PASO 5: PRESENTACIÓN (Semana 9-10)

- 5.1) Adaptar PowerPoint (Doc 5) con datos reales
- 5.2) Ensayar presentación (20-25 min)
- 5.3) Presentar ante C-Suite / Junta Directiva
- 5.4) Aprobación presupuesto

CRONOGRAMA RECOMENDADO

ENERO 2026

- └ Semanas 1-2: Preparación documentos
- └ Semanas 3-4: Lanzamiento encuesta
- └ Semanas 5: Recepción respuestas

FEBRERO 2026

- └ Semanas 1-2: Análisis + Validación PRAGMATIC
- └ Semanas 3: Generación reportes + gráficos
- └ Semana 4: Preparación presentación

MARZO 2026

- └ Semana 1: Presentación a stakeholders
- └ Semanas 2-4: Aprobación presupuesto + inicio proyectos

REQUISITOS TÉCNICOS

Software

- Encuesta online: Google Forms (gratuito) o Qualtrics (profesional)
- Análisis datos: Excel 2016+ o Google Sheets
- Presentación: PowerPoint o Google Slides
- Estadística (opcional): R, Python, SPSS

Habilidades Requeridas

- Encuestador: Comunicación, gestión datos básica
- Analista: Excel intermedio, estadística básica, interpretación resultados
- CISO presentador: Storytelling ejecutivo, comunicación estratégica
- Auditor: Conocimiento normativa (NIS2, GDPR, ENS, DORA, ISO 27001)

FAQ — PREGUNTAS FRECUENTES

P: ¿Cuánto tiempo toma completar la encuesta?

R: 45-60 minutos en línea. Si es entrevista guiada, 90 minutos.

P: ¿Cuántas personas debo encuestar?

R: 150-250 para dataset sólido. Mínimo 50 para piloto.

P: ¿Qué pasa si IMG <40?

R: Crítico. Recomendación: Contratación consultor externo + evaluación profunda.

P: ¿Cada cuánto debo repetir?

R: Anualmente obligatorio. Semestral recomendado post-implementación mejoras.

P: ¿Los datos son confidenciales?

R: Sí. Anonimizados, cumplimiento GDPR, solo análisis agregado.

P: ¿Cómo interpreto PRAGMATIC score <3.0?

R: Métrica poco útil. Revisar definición, complementar con métrica alternativa, o usar solo con auditor externo.

SOPORTE Y CONTACTO

Equipo

- Investigadores: Instituto de Ciberseguridad
- Validación: INCIBE (Instituto Nacional de Ciberseguridad)
- Análisis: Consorcio de Científicos de Datos

Canales

- Email técnico: support@cra-cyber.es
- FAQ en línea: <https://cra-cyber.es/faq>
- Forum usuarios: <https://comunidad.cra-cyber.es>
- Reportar bugs: issues@cra-cyber.es

Capacitación

- Webinar introductorio: Primer viernes mes (16:00 CET)
- Certificación implementadores: Programa 3 semanas (virtual)
- Consultoría in-situ: Disponible (tarifa consultor)

CITACIÓN ACADÉMICA

"Kit de Evaluación GQM+PRAGMATIC para Madurez Ciberseguridad (CRA-Cyber) v2.1, Enero 2026. Integración de Goal-Question-Metric (Basili, NASA) + PRAGMATIC (Glasgow, OHSU).
Instituto Nacional de Ciberseguridad (INCIBE), España."

LICENCIA Y TÉRMINOS

Licencia: CC-BY 4.0 (Creative Commons Attribution)

Permitido:

- Usar, adaptar, traducir, compartir
- Con atribución a INCIBE + Equipo desarrollo

Prohibido:

- Uso comercial directo (venta sin consentimiento)
- Retirar atribuciones

REGISTRO DE CAMBIOS

Versión	Fecha	Cambios
v2.1	Enero 2026	Lanzamiento oficial: Integración GQM+PRAGMATIC, Mapeo NIS2 completo, Dashboard automatizado
v2.0	Septiembre 2025	Beta: Piloto 50 orgs, Feedback sectorial integrado
v1.0	Abril 2025	Alfa: Diseño conceptual inicial

AGRADECIMIENTOS

Agradecemos a 50+ organizaciones que participaron en piloto, expertos de INCIBE, CCN-CNI, universidades españolas, y comunidad académica ciberseguridad.

Última actualización: 21 de enero de 2026

Versión: 2.1

Status: Producción

Soporte: support@cra-cyber.es

Kit CRA-Cyber GQM+PRAGMATIC v2.1 — Guía de Inicio Rápido